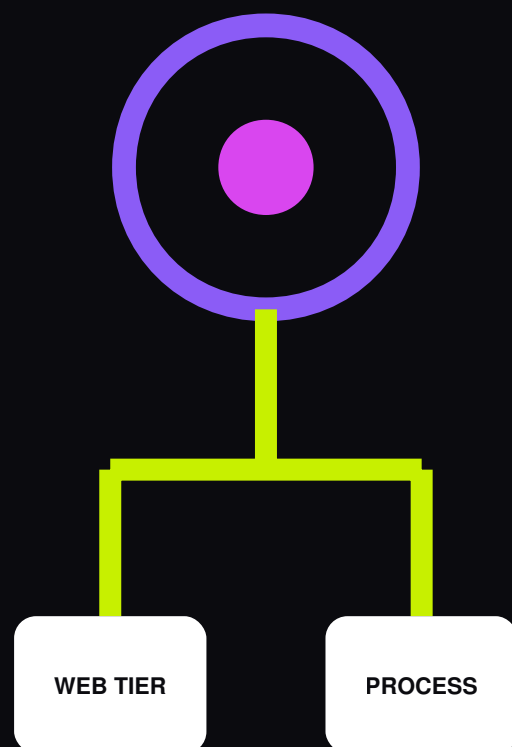


PEOPLESOFT WEBLOGIC JAVA TO SHELL

Hunts for cmd.exe, sh, or bash spawned directly by a WebLogic Java process on explicitly inventoried PeopleSoft web-tier nodes.

HUNTING QUERY

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE

29 September 2026

STATUS

Untested implementation
sketch

PRIMARY PLATFORM

Microsoft Defender XDR

OPERATIONAL VALUE

9.8 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.8

Hunts for cmd.exe, sh, or bash spawned directly by a WebLogic Java process on explicitly inventoried PeopleSoft web-tier nodes.

STATUS

Hunting query

Untested implementation sketch; Confidence Medium.

1

PRIMARY TABLE

0

JOINS

0

SECONDARY RULES

2

VALIDATION GATES

Evidence boundary

A result proves only a Java-to-shell process relationship on an inventoried PeopleSoft server. It does not prove an encoded request, successful deserialization, web-shell deployment, data theft, actor identity, or CVE exploitation.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Mandiant observed renewed mass exploitation of CVE-2026-35273 after UNC6240 encoded one path character to bypass literal WAF rules.
- 2 Fileless execution appeared on hosts as cmd.exe or /bin/sh spawned by the WebLogic Java process; the source also recommends monitoring bash.
- 3 The same campaign deployed JSP web shells, SIDEYE, Neo-reGeorg, and MeshAgent, but those mutable artifacts are not query conditions.

Detection hypothesis

If an attacker executes commands through vulnerable PSEMHUB or a deployed JSP shell, endpoint telemetry should expose a shell spawned directly by WebLogic Java. Distinction requires exact server scope, service ownership, change evidence, and command review.

Unconfirmed elements

A result proves only a Java-to-shell process relationship on an inventoried PeopleSoft server. It does not prove an encoded request, successful deserialization, web-shell deployment, data theft, actor identity, or CVE exploitation.

Logic: Behavioral process lineage **ATT&CK:** T1059.003 / T1059.004



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Defender for Endpoint process telemetry from every PeopleSoft web-tier node; a verified DeviceName FQDN inventory; direct parent-child lineage; complete process command lines.

OPTIONAL ENRICHMENT

WebLogic service owner, maintenance and change records, raw PIA access logs, WAF logs, PSEMHUB.war file events, network telemetry, and PeopleSoft service-account inventory.

Fields	Reliability	Use
Timestamp, DeviceId, DeviceName	Documented	Query or triage
FileName, FolderPath	Documented	Query or triage
ProcessCommandLine, ProcessId	Documented	Query or triage
AccountDomain, AccountName	Documented	Query or triage
InitiatingProcessFileName	Documented	Query or triage
InitiatingProcessFolderPath	Documented	Query or triage
InitiatingProcessCommandLine, InitiatingProcessId	Documented	Query or triage
InitiatingProcessAccountDomain, AccountName, ReportId	Documented	Query or triage

Excluded

No HTTP body, exploit success, web-shell presence, data theft, actor attribution, IOC dependency, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
let PeopleSoftWebTierDevices = dynamic([
  "<REPLACE_WITH_PEOPLESOFT_WEB_TIER_FQDN>"
]);
DeviceProcessEvents
| where DeviceName in~ (PeopleSoftWebTierDevices)
| where InitiatingProcessFileName in~ ("java.exe", "java")
| where FileName in~ ("cmd.exe", "sh", "bash")
| project Timestamp, DeviceId, DeviceName, FileName,
  FolderPath, ProcessCommandLine, AccountDomain,
  AccountName, ProcessId, InitiatingProcessFileName,
  InitiatingProcessFolderPath, InitiatingProcessCommandLine,
  InitiatingProcessId, InitiatingProcessAccountDomain,
  InitiatingProcessAccountName, ReportId
| order by Timestamp desc
```

WINDOW

Analyst-selected;
none embedded

THRESHOLD

None

JOIN / SEQUENCE

None

SCOPE

Exact PeopleSoft
web-tier FQDNs



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw process event, device identity, parent and child paths, command lines, accounts, PIDs, timestamp, and ReportId.

2

Confirm

Identify the PeopleSoft owner, WebLogic service account, maintenance window, approved job, and matching change record.

3

Enrich

WebLogic service owner, maintenance and change records, raw PIA access logs, WAF logs, PSEMHUB.war file events, network telemetry, and PeopleSoft service-account inventory.

4

Scope

Review raw PIA and WAF logs, PSEMHUB.war file events, network connections, credential exposure, and activity on every load-balanced node.

Expected benign overlap

WebLogic administration, deployment, diagnostics, patching, and approved application jobs may spawn a shell. Baseline by exact node, service owner, account, command, path, and change record. Never allowlist java or a service account globally.

Response boundary

A result proves only a Java-to-shell process relationship on an inventoried PeopleSoft server. It does not prove an encoded request, successful deserialization, web-shell deployment, data theft, actor identity, or CVE exploitation.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. Replace the placeholder with exact DeviceName FQDNs and confirm Defender for Endpoint coverage for every web-tier node.
2. Run an authorized benign WebLogic task that starts a shell; verify the direct parent-child relationship and complete command lines.
3. Measure representative volume and map recurring commands to owners, maintenance windows, and change records.
4. Compare the endpoint event with raw PIA/WAF logs without assuming URI normalization or a cross-source correlation key.

Decision criteria

Success: The benign test returns the exact node, direct Java parent, shell child, account, PIDs, and complete command lines; recurring legitimate activity is attributable.

Rejection: Parent-child lineage is unstable, asset inventory is unreliable, or legitimate volume cannot be governed with narrow owner-and-command tuning.

Failure: A node is not onboarded, the placeholder remains, telemetry is missing, command lines are truncated, or execution occurs in-process without a shell child.

Platform	Decision	Missing evidence
Defender XDR	Hunting query	PeopleSoft web-tier baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts for cmd.exe, sh, or bash spawned directly by a WebLogic Java process on explicitly inventoried PeopleSoft web-tier nodes.

A result proves only a Java-to-shell process relationship on an inventoried PeopleSoft server. It does not prove an encoded request, successful deserialization, web-shell deployment, data theft, actor identity, or CVE exploitation.

MITRE ATT&CK

T1059.003 / T1059.004

References

1. Mandiant / GTIG — renewed PeopleSoft exploitation — 25 Sep 2026
2. Oracle — Security Alert CVE-2026-35273 — 10 Jun 2026
3. Microsoft Learn — DeviceProcessEvents schema — updated 7 Aug 2026
4. MITRE ATT&CK — T1059.003 and T1059.004

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.